Prüfliste für den externen Legal Review

WERKRUF · Paket A (Datenschutzerklärung, Impressum, Einwilligung, GA4) · Stand 11.11.2026 · Grundlage: produktiver Code (`main` + PR Paket A)

> **Bitte vorrangig prüfen** (rot markiert): Rechtsgrundlage für Öffnungs-/Klick-Tracking in E-Mails, geschäftliche Ansprache per E-Mail (UWG § 7), Löschfristen ohne technische Umsetzung, Einwilligungsnachweis, Drittlandgrundlage je US-Anbieter.

1. Datenempfänger (produktiv)

EMPFÄNGER	ROLLE	DATEN	WANN
Vercel Inc. (USA)	AV	IP, Seitenabruf, Browserdaten (Logs)	jeder Aufruf
Supabase Inc. (Singapur; Region EU/Frankfurt)	AV	Konto, Inhalte, Protokolle	Konto, Funktionen
Google Ireland – Anmeldung („Mit Google anmelden")	eigener Verantw.	Google-ID, E-Mail, Name	Registrierung/Login
Google – Business Profile API (`business.manage`)	Zugriff im Auftrag des Kunden	Profil, Bewertungen, Kennzahlen, Token (verschlüsselt)	nach Verknüpfung
Google – Maps Platform (Places JS)	eigener Verantw.?	IP, Suchbegriffe	nur bei Betriebssuche im Konto
Google – Analytics 4	AV (Data Processing Terms)	bereinigter Pfad, Funnel-Schritte, Cookies, IP (laut Google nicht gespeichert)	nur nach Einwilligung
Anthropic PBC (USA)	AV / Unter-AV	Sterne, Bewertungstext, Anzeigename	Antwortentwurf
Cloudinary Ltd. (USA)	AV	hochgeladene Fotos	Foto-Upload
Brevo SAS (FR)	AV	E-Mail, Name, Inhalt; Mobilnummer (SMS); Zustell-/ Öffnungs-/Klickereignisse	Mails, SMS-Bewertungsanfragen
Stripe Payments Europe Ltd. (IE)	eigener Verantw.	Zahlungsdaten (nur Stripe), Kunden-/Abo-ID bei uns	Checkout, Portal

Nicht aufgenommen (nicht produktiv): Cloudflare Turnstile und öffentlicher Places-PDF-Bericht (seit 28.09.2026 nicht erreichbar, Code liegt noch im Repo). **Entfernt** mit Paket A: Google Fonts (jetzt selbst gehostet), globales Laden der Maps-Bibliothek auf jeder Seite.

2. Zweck und Rechtsgrundlage

VERARBEITUNG	ZWECK	RECHTSGRUNDLAGE (ENTWURF)	PRÜFEN

Hosting, Logs	Auslieferung, Sicherheit	Art. 6 (1) f	–
Konto, Nutzungsbedingungen-Nachweis	Vertrag	b; Nachweis c/f	–
GBP-Verknüpfung, KI-Entwürfe, Fotos	Vertragsleistung	b (Bewertungen: AV für Kunden)	Rollenverteilung bei Bewertungsdaten
Maps-Betriebssuche	Funktion im Konto	b	ob b trägt oder Einwilligung nötig
Transaktionsmails	Vertrag	b	–
Öffnungs-/Klick-Tracking in Mails	Zustellbarkeit, Wirkung	f + Widerspruch	**in DE umstritten; ggf. Einwilligung oder Abschalten für Kundenmails**
SMS-Bewertungsanfragen	Leistung für Betrieb	AV (Betrieb verantwortlich)	Hinweis-/Einwilligungspflicht des Betriebs gegenüber Endkunden
Geschäftliche Ansprache (Akquise)	Kundengewinnung	f, Art. 14-Information, Art. 21	**UWG § 7 Abs. 2 Nr. 2: E-Mail ohne Einwilligung auch B2B unzulässig – DSGVO-Text heilt das nicht**
Zahlungen	Vertrag, Buchhaltung	b, c	–
Webanalyse GA4	Reichweite, Funnel	a + § 25 (1) TDDDG	–

3. Drittlandtransfer

- Text sagt: **Google LLC, Stripe Inc.** → EU-US Data Privacy Framework; **Anthropic, Cloudinary, Supabase** → Standardvertragsklauseln; Vercel → „DPF, soweit zertifiziert, sonst SCC" (aus AVV übernommen).
- **Bitte je Anbieter gegen die aktuelle DPF-Liste prüfen und den Text vereinheitlichen (insb. Vercel, Cloudinary, Anthropic).**
- Brevo: Verarbeitung in der EU (laut AVV-Anlage 3).

4. Speicherdauer / Löschung

DATEN	STAND IM CODE	PRÜFEN
Konto + Inhalte	Selbstlöschung im Konto: löscht Konto, Token, Fotos (Cloudinary), beendet Abo; Leads anonymisiert	–
Rechnungsdaten	Text: 6–10 Jahre gesperrt	Umsetzung bei Stripe/Buchhaltung
Akquise-Leads	keine automatische Löschung; Text: „sobald nicht mehr benötigt"	**konkrete Frist festlegen und technisch umsetzen**
Support-Anfragen	keine automatische Löschung	**Frist festlegen**

Aktions-Links (Status-Mail)	Bereinigungsfunktion vorhanden, **nicht** eingeplant	Job einplanen (Text verspricht keine Frist)
Mail-Ereignisse	ohne IP/Gerät; Aufbewahrung offen	Frist festlegen
GA4	Text: 14 Monate	**in GA4 einstellen (Verwaltung → Datenaufbewahrung)**
Server-Logs Vercel/Supabase	Anbieter-Standard	Fristen der Anbieter im Text nennen?

5. Cookies / Local Storage

- Ohne Einwilligung: **keine Cookies**. Local/Session Storage: Anmeldung (`sb-…-auth-token`), Einwilligung (`werkruf_consent_v1` , ohne Personenbezug), Empfehlungscode (`werkruf.referral`), kurzlebige Sitzungsmerker. Einordnung: § 25 Abs. 2 Nr. 2 TDDDG.
- Mit Einwilligung: `_ga` , `_ga_<ID>` (bis 2 Jahre).
- Prüfen: Empfehlungscode als „unbedingt erforderlich"?

6. Auftragsverarbeitung

- AV-Verträge abgeschlossen/akzeptiert? Vercel, Supabase, Brevo, Anthropic, Cloudinary, Google Analytics (Data Processing Terms in GA4-Verwaltung).
- **AVV-Seite (`/avv`), Anlage 3: Brevo nur als „Versand von E-Mails an den Kunden" – SMS an Endkunden fehlt. Nicht Teil von Paket A, bitte mitprüfen.**
- Rolle bei Google-Bewertungen (Datenschutzerklärung Abschnitt 17) wie in der AVV.

7. Einwilligung / Widerruf

- **Consent Mode „Basic": vor Zustimmung kein Skript, kein Request (im Browser geprüft).**
- **„Ablehnen" und „Zustimmen" gleichwertig (gleiche Größe, gleicher Stil, gleiche Ebene); Hinweis nicht modal.**
- **Widerruf jederzeit: Footer „Cookie-Einstellungen" und Knopf in der Datenschutzerklärung; stoppt sofort, löscht GA-Cookies.**
- Kein Banner und keine Messung auf Token-Seiten, Bestätigungs-/Magic-Link-Seiten, `/admin` (Positivliste).
- **Nachweis der Einwilligung (Art. 7 Abs. 1): nur im Browser gespeichert (Version, Zeitpunkt), keine serverseitige Protokollierung. Reicht das?**
- Banner nur in Deutsch, Du-Ansprache (wie die übrige Oberfläche); Rechtstexte in Sie-Form.

8. Google-Verbindungen

- Login mit Google (Supabase OAuth) ≠ Verknüpfung Unternehmensprofil – im Text getrennt.
- Business Profile API: Scope `business.manage` , Token AES-256-GCM, Limited-Use-Erklärung (unverändert übernommen, Weitergabe an Anthropic jetzt ausdrücklich genannt).
- Maps Places JS nur bei Betriebssuche im Konto; Schlüssel öffentlich (Browser).

9. Stripe / Brevo

- Stripe: Vertragspartner für EU-Kunden als *Stripe Payments Europe, Ltd.* angegeben (bisher Stripe, Inc. USA) – bitte bestätigen.

- **Brevo: Öffnungs-/Klick-Tracking ist im Konto aktiv und läuft für alle Mails (auch Kundenmails). Rechtsgrundlage f – siehe Abschnitt 2.**
- Brevo SMS: Mobilnummer nur als HMAC-Prüfwert gespeichert; Versand im Auftrag des Betriebs.

10. Vercel / Supabase

- Vercel: Rewrites `/b/…` und `/p/fp/…` an Supabase; `/b/…` ohne Klickzählung, `/p/fp/…` zählt den Aufruf (Akquise).
- Supabase: Datenbank EU; Zugriff aus Drittland nicht ausgeschlossen (SCC).

11. Analytics – technische Umsetzung

- Mess-ID per Umgebungsvariable `REACT_APP_GA4_MEASUREMENT_ID`; ohne sie kein Banner, kein GA.
- An GA4 nur Origin + bereinigter Pfad (Positivliste, Kennungen gekürzt), kein Query, kein Fragment; Referrer nur als Domain; Seitentitel = Pfad.
- Funnel: `signup_start` (method), `signup_complete`, `google_connect_start` (reconnect), `google_connect_success`, `checkout_start` (plan), `checkout_success`. Keine IDs, Mails, Namen.
- `allow_google_signals: false`, keine Werbesignale. In der GA4-Verwaltung zusätzlich: Google-Signale aus, Datenfreigabe-Einstellungen aus, Datenaufbewahrung 14 Monate.

12. Impressum

- § 5 DDG statt § 5 TMG; § 18 Abs. 2 MStV statt § 55 RStV; Haftung §§ 7–10 DDG.
- Hinweis auf die OS-Plattform entfernt (EU-Plattform seit 20.07.2025 abgeschaltet).
- Kleinunternehmer § 19 UStG – Status bestätigen; ggf. USt-IdNr./Wirtschafts-IdNr.
- Angaben aus einer Quelle (`src/config/anbieter.js`), auch für die Datenschutzerklärung.